

TP2 BIOC 3

SOMMAIRE

Exercice 1 :

Exercice 2 :

Exercice 3 :

Exercice 4 :

Exercice 5 :

Exercice 6 :

Exercice 1 :

1. 1 Pour le premier exercice nous allons importer le travail réalisé par M.Grospire puis on l'importe sur pia :

Nouveau PIA



ou

Importer PIA



PIA
(IMPORT) PIA TESTOP

Saisie
Luc, FRET

Évaluation
Pierre, GROSPIRE

Validation
Pierre, GROSPIRE

Catégorie
Catégorie

Date
15/09/2019

Statut
En cours

30%

Éditer

1.2/ Pour le risque d'accès illégitime à des données :

Comment estimez-vous la **gravité du risque**, notamment en fonction des impacts potentiels et des mesures prévues ?



(Non définie) Négligeable Limitée Importante Maximale

Une personne qui obtiendrait un accès non autorisé aux serveurs pourrait consulter ou extraire des données à caractère personnel des salariés (coordonnées, informations professionnelles). Cela entraînerait une atteinte à la vie privée, un risque d'usurpation d'identité et des conséquences juridiques pour l'entreprise.

0 commentaire(s)

02/10/2025  Commenter

Comment estimez-vous la **vraisemblance du risque**, notamment au regard des menaces, des sources de risques et des mesures prévues ?



(Non définie) Négligeable Limitée Importante Maximale

il est peu probable qu'une attaque survienne sur les serveurs d'une entreprise spécialisée dans la fabrication de bancs, car ils ne représentent pas une cible prioritaire

Pour le risque de modification non désiré de données :

Comment estimez-vous la **gravité du risque**, notamment en fonction des impacts potentiels et des mesures prévues ?



si quelqu'un modifie les données des salariés, cela peut complètement fausser leurs informations personnelles et professionnelles, provoquer des erreurs dans leur travail et avoir de grosses conséquences pour l'entreprise.

0 commentaire(s)

15/09/2019

Commenter

Comment estimez-vous la **vraisemblance du risque**, notamment au regard des menaces, des sources de risques et des mesures prévues ?



cela a peu de chances d'arriver grâce aux protections déjà mises en place, mais ce n'est pas impossible si quelqu'un arrive à accéder aux serveurs ou fait une erreur.

Pour le risque de disparition des données :

Comment estimez-vous la **gravité du risque**, notamment en fonction des impacts potentiels et des mesures prévues ?



la disparition des données personnelles des salariés pourrait entraîner la perte complète de leurs informations (coordonnées, parcours professionnel) gêner la gestion RH et avoir de fortes conséquences pour l'entreprise (impossibilité de gérer les dossiers, perte de confiance, risque légal).

0 commentaire(s)

02/10/2025

Commenter

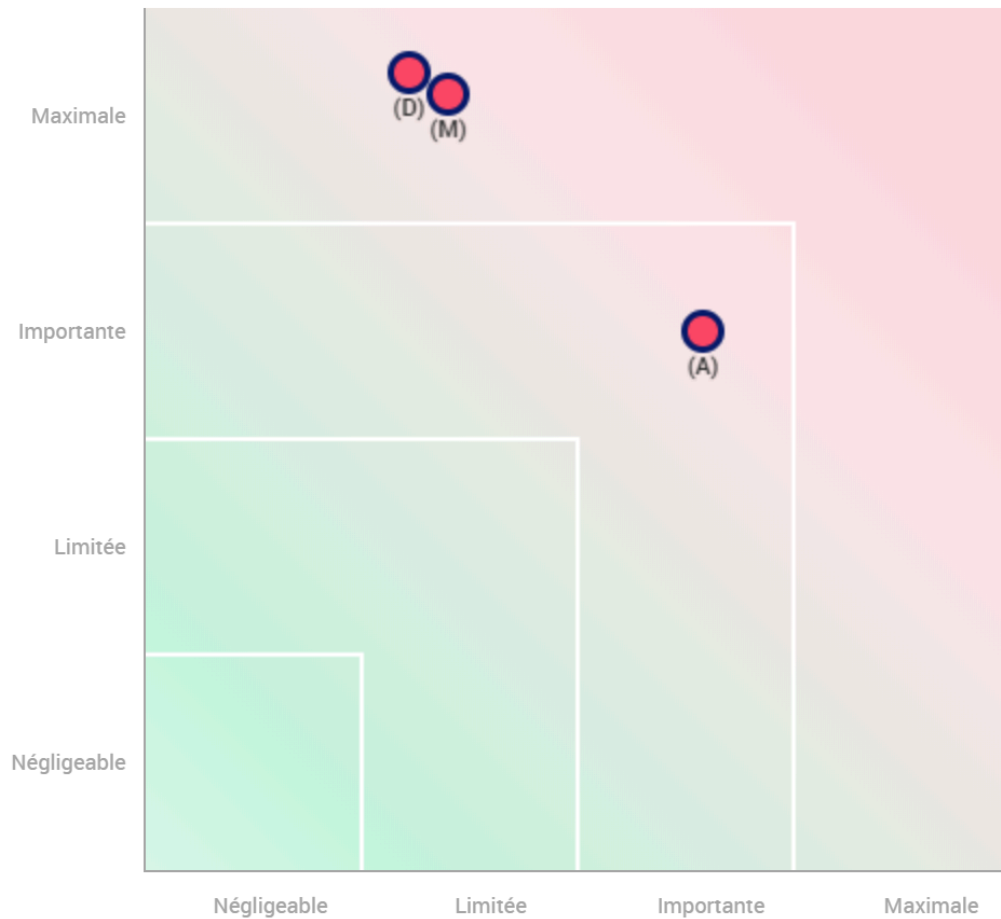
Comment estimez-vous la **vraisemblance du risque**, notamment au regard des menaces, des sources de risques et des mesures prévues ?



ce risque est peu probable car des sauvegardes existent, mais il reste possible en cas de panne des serveurs, d'erreur humaine ou d'attaque. Il serait utile de prévoir une duplication ou une sauvegarde automatique pour réduire l'impact.

1.3) Pour le moment la cartographie des risques et la suivante :

Gravité du risque



- Mesures prévues ou existantes
- Avec les mesures correctives mises en oeuvre
- (A)ccès illégitime à des données
- (M)odification non désirée de données
- (D)isparition de données

Vraisemblance du risque

15/09/2019

1.4)

Accès illégitime des données :

Évaluation

✕ À corriger

🔄 Améliorable

✓ Acceptable

02/10/2025

Commentaire d'évaluation

Il faudrait tout de même réfléchir à renforcer la sécurité des serveurs, par exemple en mettant en place une duplication (sauvegarde) des données afin d'éviter toute perte de travail en cas d'attaque.

Plan d'action / mesures correctives

Pour réduire ce risque, il serait utile de mettre en place une authentification à deux facteurs pour l'accès aux postes de travail et aux serveurs contenant les données sensibles. Le renforcement de la politique de mots de passe (avec des codes plus complexes et un renouvellement régulier) permettrait également d'améliorer la protection. En complément, un système de journalisation pourrait être instauré pour détecter toute tentative d'accès non autorisée. Enfin, une formation du personnel à la sécurité informatique et à la reconnaissance des tentatives de phishing serait un bon moyen de prévenir les erreurs humaines.

Prenant en compte le plan d'action, comment ré-évaluez-vous la **gravité de ce risque** (Accès illégitime à des données) ?



(Non définie) Négligeable Limitée Importante Maximale

Prenant en compte le plan d'action, comment ré-évaluez-vous la **vraisemblance de ce risque** (Accès illégitime à des données) ?



(Non définie) Négligeable Limitée Importante Maximale

Pour le risque de modification non désiré de données :

Évaluation

✕ À corriger

🔄 Améliorable

✓ Acceptable

02/10/2025

Commentaire d'évaluation

Le risque de modification non désirée de données concerne la possibilité qu'une information personnelle d'un salarié soit modifiée par erreur ou de manière malveillante. Cela pourrait entraîner des incohérences dans les dossiers, comme des erreurs dans le profil de poste, le plan de formation ou l'historique professionnel. Même si certaines protections existent déjà, comme le contrôle des accès ou le chiffrement, le risque demeure réel en cas d'erreur humaine ou de mauvaise manipulation.

Plan d'action / mesures correctives

Pour limiter ce risque, il serait utile d'instaurer un système de sauvegarde automatique et régulière des données, afin de pouvoir restaurer les informations en cas d'erreur. La mise en place d'une journalisation (traçabilité des modifications) permettrait également d'identifier rapidement la source d'un changement non autorisé. Enfin, la limitation des droits d'accès aux seules personnes concernées et la formation des employés à la manipulation sécurisée des données contribueraient à réduire les erreurs et à renforcer la fiabilité du système.

Prenant en compte le plan d'action, comment ré-évaluez-vous la **gravité de ce risque** (Accès illégitime à des données) ?



(Non définie) Négligeable Limitée Importante Maximale

Prenant en compte le plan d'action, comment ré-évaluez-vous la **vraisemblance de ce risque** (Accès illégitime à des données) ?



(Non définie) Négligeable Limitée Importante Maximale

Pour le risque de disparition des données :

Évaluation

✕ À corriger

🔄 Améliorable

✓ Acceptable

02/10/2025

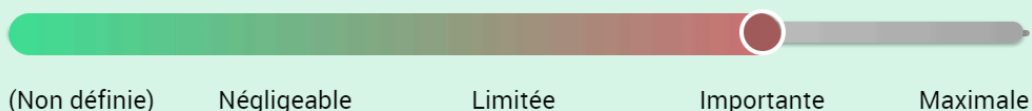
Commentaire d'évaluation

Le risque de disparition de données concerne la perte totale ou partielle des informations personnelles des salariés, que ce soit à cause d'une panne du serveur, d'une erreur de manipulation ou d'une attaque informatique. Une telle perte pourrait fortement perturber la gestion du personnel, rendre certains dossiers incomplets et nuire à la confiance des salariés envers l'entreprise. Même si une sauvegarde sur disque dur externe est déjà prévue, cela reste insuffisant pour garantir une restauration rapide et complète des données en cas d'incident majeur.

Plan d'action / mesures correctives

Pour limiter ce risque, il serait important de mettre en place une sauvegarde automatique et redondante (copie des données sur plusieurs supports, dont un hébergement sécurisé en ligne). Des tests réguliers de restauration devraient être réalisés afin de vérifier que les sauvegardes sont réellement exploitables. De plus, un renforcement de la sécurité physique et logique des serveurs permettrait de réduire le risque de perte liée à une défaillance technique ou à une attaque. Enfin, une procédure claire de gestion des incidents devrait être mise en place pour assurer une réaction rapide en cas de disparition de données.

Prenant en compte le plan d'action, comment ré-évaluez-vous la **gravité de ce risque** (Disparition de données) ?

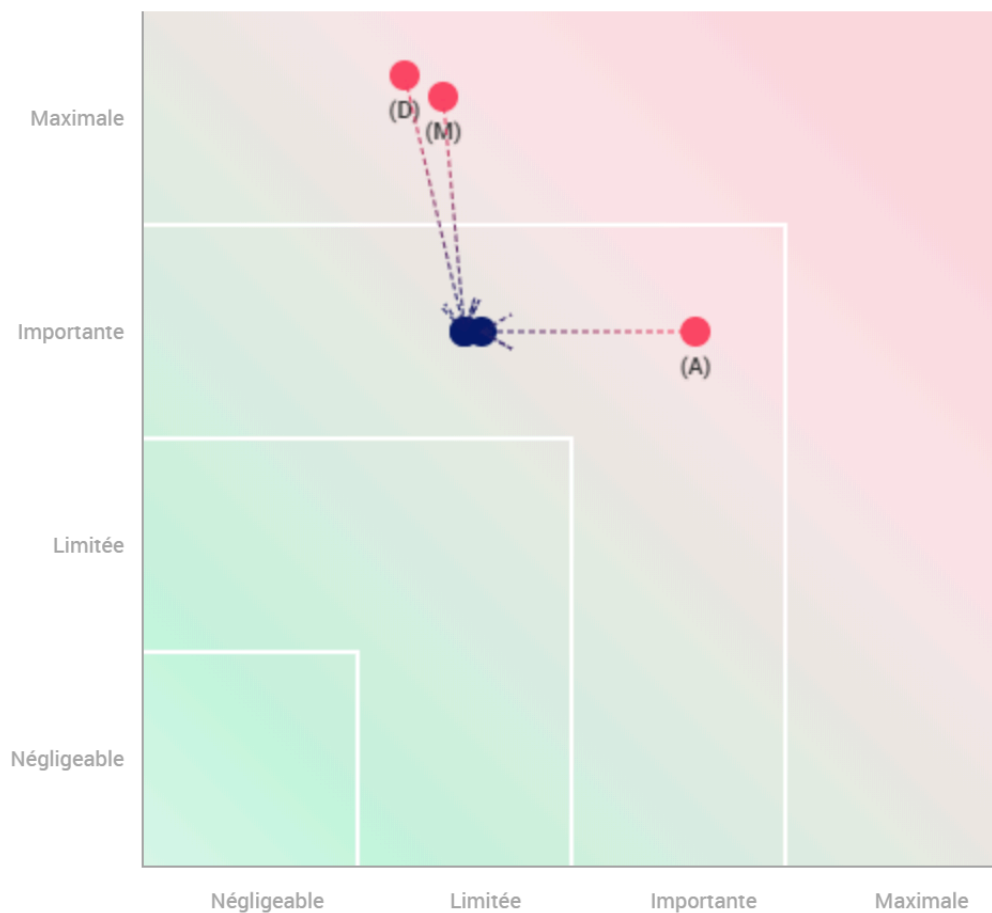


Prenant en compte le plan d'action, comment ré-évaluez-vous la **vraisemblance de ce risque** (Disparition de données) ?



1.5) Après les mesures mises en place, les risques ont diminué. La gravité reste importante, mais la vraisemblance est désormais limitée grâce au renforcement de la sécurité, aux sauvegardes et au contrôle des accès. Les données sont donc mieux protégées et les risques deviennent plus maîtrisés.

Gravité du risque



- Mesures prévues ou existantes
- Avec les mesures correctives mises en oeuvre
- (A)ccès illégitime à des données
- (M)odification non désirée de données
- (D)isparition de données

Vraisemblance du risque

Exercice 2 :

2.1) La cartographie des traitements de données personnelles consiste à recenser et représenter l'ensemble des traitements de données effectués par une organisation. Elle permet de savoir quelles données sont collectées, pour quelles finalités, par qui elles sont utilisées, où elles sont stockées et combien de temps elles sont conservées.

Cette démarche a pour but de rendre la gestion des données plus claire et conforme au RGPD. Elle aide l'entreprise à mieux comprendre ses pratiques, à repérer les risques pour la vie privée des personnes concernées et à mettre en place des mesures de sécurité adaptées.

Les enjeux sont donc importants : la cartographie garantit la transparence, la conformité à la loi, la protection des données personnelles et la confiance des salariés, clients ou usagers.

2.2) Le registre des traitements est un document obligatoire prévu par le RGPD. Il répertorie de manière détaillée tous les traitements de données réalisés par l'organisation : les finalités, les catégories de données, les destinataires, la durée de conservation et les mesures de sécurité appliquées.

Ce registre constitue la base de travail indispensable avant d'établir la cartographie. En effet, sans connaître précisément les traitements existants, il est impossible de les représenter et d'identifier leurs liens ou leurs risques.

Ainsi, le registre permet de décrire les traitements, tandis que la cartographie permet de les visualiser et de les analyser. C'est pourquoi le registre est une étape préalable et essentielle pour construire une cartographie complète et fiable.

Exercice 3 :

3.1) Dans le cas de Castorama, les données personnelles des clients sont collectées lorsqu'ils utilisent les services du site internet, créent un compte client, passent une commande ou participent à un programme de fidélité. Ces données peuvent aussi être recueillies lors de leurs achats en magasin ou de leurs échanges avec le service client. Elles sont ensuite stockées dans les bases de données du groupe Kingfisher, dont Castorama fait partie, et peuvent être partagées avec d'autres entités du groupe comme Brico Dépôt, Screwfix ou B&Q. Certaines informations peuvent aussi être utilisées pour des analyses statistiques ou marketing, et parfois transmises à des partenaires extérieurs, mais toujours dans le cadre légal prévu.

3.2) Les traitements de données réalisés par Castorama concernent principalement la gestion de la relation client. Cela comprend la collecte des coordonnées, la gestion des commandes, le suivi des livraisons, la facturation et le service après-vente. L'entreprise utilise aussi ces données pour mieux connaître les besoins des clients, leur proposer des produits adaptés et améliorer ses services. Enfin, certaines données peuvent être analysées à des fins statistiques ou partagées avec d'autres marques du groupe Kingfisher pour harmoniser la stratégie commerciale.

Exercice 4 :

4.1) Dans la vidéo, on voit que les données personnelles peuvent être collectées de différentes façons, par exemple à travers des questionnaires en ligne, des enregistrements vocaux ou vidéos, ou encore sur les réseaux sociaux. Ces données sont ensuite gardées dans des fichiers ou dans des bases de données pour être traitées plus tard. Elles peuvent aussi être diffusées par mail ou par téléphone selon les besoins de l'entreprise.

4.2) Les traitements présentés concernent surtout la gestion du personnel de l'entreprise. On voit aussi le contrôle d'accès par badge pour entrer dans les locaux, ainsi qu'un système de vidéosurveillance. Ces traitements permettent de sécuriser les lieux et d'assurer une meilleure organisation du travail.

4.3) Les obligations légales expliquées dans la vidéo précisent que chaque traitement doit avoir une finalité claire. Il faut limiter la collecte aux seules données vraiment nécessaires, veiller à ce qu'elles soient pertinentes, et les supprimer une fois qu'elles ne servent plus. L'entreprise doit aussi garantir la sécurité et la confidentialité de toutes les informations personnelles.

4.4) Quand une entreprise ne respecte pas la sécurité des données, elle peut recevoir de lourdes sanctions. Les amendes peuvent aller jusqu'à 20 millions d'euros ou 4 % du chiffre d'affaires du groupe. Si la sécurité n'est pas suffisante, l'amende peut atteindre 10 millions d'euros ou 2 % du chiffre d'affaires. Dans les cas les plus graves, il peut même y avoir des peines de prison et la publication des infractions.

Exercice 5 :

Scénario	Sécurité	Sûreté	Justifications
L'ensemble des serveurs est hors service à cause d'une inondation du local technique.			Il s'agit d'un incident d'origine naturelle et non d'une action malveillante

Les données d'un hôpital deviennent illisibles à la suite d'une attaque de type ransomware.	X		L'altération résulte d'une action malveillante visant à nuire au système.
L'apparence du site vitrine d'une entreprise est modifiée pendant un week-end par des personnes malveillantes	X		La modification est due à une attaque volontaire sur le site web.
Une surcharge électrique provoquée par des travaux dans les locaux entraîne une panne des routeurs.		X	La panne provient d'un accident technique et non d'une intention malveillante

Exercice 6 :

Données	Caractère personnel	Justifications
Le nom de l'enseigne du magasin Carrefour	Non	Ce nom identifie une entreprise, pas une personne physique, il ne s'agit donc pas d'une donnée personnelle.
L'adresse courriel professionnelle d'un directeur des services informatiques	Non	L'adresse est liée à l'organisation et ne permet pas d'identifier directement une personne à titre individuel.
Une photo postée sur un réseau social	oui	Selon le contenu de l'image, elle peut permettre de reconnaître ou d'identifier une personne.
Une vidéo de présentation de son parcours professionnel envoyée dans le cadre d'un recrutement	oui	Elle contient des éléments permettant d'identifier clairement l'individu.
Les coordonnées GPS de localisation d'un smartphone	oui	Elles permettent de déterminer l'emplacement d'une personne, ce qui la

		rend identifiable.
Le groupe sanguin d'un patient stocké sur un serveur médical	oui	Cette information de santé est propre à un individu et liée à son identité.
Le numéro de Sécurité sociale d'un salarié enregistré sur sa fiche d'embauche	oui	Ce numéro identifie une personne de manière unique dans les systèmes administratifs.